

ABANGCEBU AI — ARCHITECTURAL SPECIFICATION

User Login & Session Token Lifecycle Specification

Ticket Reference: SCRUM-57 (Authentication Planning)

Target Framework: Next.js 16 (App Router) + Supabase Auth

Version: 1.0.0 (Approved Architecture)

Database Schema: PostgreSQL 15+ (profiles, kyc_verifications)

Author: John Lloyd Ando (Engineering Team)

Sprint: Sprint 1 (Architecture & Governance)

1. Purpose & System Overview

The login and session lifecycle represents the primary identity verification gate in **AbangCebu AI**. It guards privileged platform actions—such as revealing verified landlord contact details, submitting inquiries, saving favorite listings, and managing rental properties across Metro Cebu.

This specification governs session progression, cryptographic token rotation, and Edge Middleware session refreshes using `@supabase/ssr`. It guarantees complete immunity against Cross-Site Scripting (XSS) token theft, automated Token Family Revocation upon replay attacks, and instantaneous account expulsion for suspended users.

1.1 Source Document Mapping & Cross-System Traceability

Source Specification	Architectural Requirement & System Integration
docs/what-is-abangcebu-ai.md	Preserves unauthenticated map exploration while cleanly gating contact actions (P04). Preserves search coordinates across login redirects.
docs/auth-registration-spec.md	Enforces identity verification rules, email confirmation check (<code>auth.users.email_confirmed_at IS NOT NULL</code>), and role assignment.
docs/users-and-profiles-schema.md	Enforces FK constraint between <code>auth.users.id</code> and <code>public.profiles.id</code> , role enum (<code>renter</code> , <code>landlord</code> , <code>admin</code>), and <code>is_suspended</code> flag checks.
docs/renter-persona.md	Accommodates mobile-first students and BPO workers (Mika persona) via 30-day "Remember Me" sessions and resilient background token refreshes.
docs/rbac-matrix.md & rls-policies.md	Directs post-login role routing and feeds JWT claims into PostgreSQL RLS (<code>auth.jwt() ->> 'role'</code>). Gated landlord phone numbers remain masked until authenticated.

2. Session Lifecycle State Machine

User sessions move through five deterministic states governed by cryptographic tokens, expiration timers, and database state:



Current State	Trigger / Event	Precondition / Guard	Next State & Side Effects
UNAUTHENTICATED	Submit login form	Valid email/password structure	AUTHENTICATING : Rate-limit and Turnstile evaluated.
AUTHENTICATING	GoTrue validation passes	Email confirmed, account active	ACTIVE_SESSION : Set HTTP-Only cookies; dispatch role.
AUTHENTICATING	GoTrue validation fails	Bad credentials or unconfirmed email	UNAUTHENTICATED : 401 response; audit log emitted.
ACTIVE_SESSION	Middleware request (TTL < 5m)	Valid refresh token exists	REFRESHING : Background RTR code exchange.
REFRESHING	RTR exchange succeeds	Token valid within grace window	ACTIVE_SESSION : Update request & response cookies.
REFRESHING	RTR token reuse detected	Token presented twice outside grace	STALE_REVOKED : Token Family Revocation executed.
ACTIVE_SESSION	Explicit logout / suspension	profiles.is_suspended = true	STALE_REVOKED : Invalidate tokens; clear cookies.

3. Login Request / Response Contracts

3.1 Payload Specification (POST /api/auth/login)

The login endpoint accepts a strictly typed payload, validates Cloudflare Turnstile tokens, and enforces rate limits (5 attempts per 15 minutes per IP).

```
{
  "email": "mika.student@cit.edu",
  "password": "CebuStudent2026!#",
  "rememberMe": true,
  "turnstileToken": "0.X_TurnstileTokenPayload_X..."
}
```

3.2 Success Response Structure (HTTP 200 OK)

```
{
  "success": true,
  "data": {
    "user": {
      "id": "c1f7a014-9964-4e78-8314-87bfd992160a",
      "email": "mika.student@cit.edu",
      "role": "renter",
      "fullName": "Mikaela Santos",
      "phoneNumber": "+639171234567",
      "isEmailConfirmed": true,
      "createdAt": "2026-09-29T05:00:00.000Z"
    },
    "session": {
      "accessToken": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...",
      "refreshToken": "v1.MRTek9e3...",
      "tokenType": "bearer",
      "expiresIn": 3600,
      "expiresAt": 1790664600
    },
    "redirectUrl": "/search"
  },
  "message": "Authentication successful. Session initialized."
}
```

4. JWT Access Token Payload Structure & Claims

Supabase Auth signs JWT access tokens using HMAC-SHA256 with the Supabase JWT secret. They have a strict 1-hour lifespan (3,600s). PostgreSQL Row Level Security extracts claims directly from `auth.jwt()`.

Claim Key	Type	Example Value	Architectural Purpose & Security Rule
sub	UUID (String)	"c1f7a014-..."	Subject identifier; maps directly to <code>auth.users.id</code> and <code>public.profiles.id</code> .
role	String	"authenticated"	Postgres internal database role; enables authenticated RLS execution.
email	String	"mika@cit.edu"	Verified primary email address of the account.
exp	Unix Timestamp	1790664600	Expiration timestamp; evaluated by Next.js middleware and Postgres RLS.
user_metadata	JSON Object	{"role": "renter"}	User claims mirror; verified against <code>public.profiles.role</code> for RLS policies.
session_id	UUID (String)	"e3b0c442-..."	Unique identifier for active session; enables selective revocation.
aal	String	"aa11"	Authenticator Assurance Level (MFA support readiness).

Zero-Trust Database Rule: Application Route Handlers and Server Actions must treat the JWT as a fast, coarse gate. Authoritative permission checks always resolve against `public.profiles` in the database kernel to ensure instant lockout if suspended.

5. Refresh Token Rotation (RTR) Architecture

AbangCebu AI implements **Refresh Token Rotation (RTR)** under RFC 6749 guidelines to eliminate long-lived credential theft risks. Every time a refresh token is presented to obtain a new access token, it is immediately invalidated and replaced with a cryptographically distinct refresh token.

5.1 30-Second Concurrency Grace Period

To prevent race conditions when multiple browser tabs or concurrent fetch requests issue simultaneous refresh requests, Supabase GoTrue supports a **30-second grace period**. During this window, presentation of the immediate predecessor token returns the same newly-issued token pair rather than triggering an attack alarm.

5.2 Token Family Revocation (Replay Attack Defense)

If a previously-used refresh token is presented *outside* the 30-second grace window, the system flags a **Token Replay Attack**:

- GoTrue immediately marks the entire **Token Family** as compromised.
- All active sessions, access tokens, and refresh tokens for that user account are revoked globally across all devices.
- Next.js middleware clears all browser cookies on the next incoming request and redirects to `/login?error=SESSION_REVOKED`.
- A high-priority security audit record is written to the audit log.

6. HTTP-Only Cookie Storage Strategy & Chunking

Tokens are strictly prohibited from being saved in browser `localStorage` or `sessionStorage`. The entire session is persisted in encrypted, HTTP-Only cookies managed via `@supabase/ssr`.

6.1 Cookie Security Attributes

Attribute	Value	Defense Guarantee
<code>HttpOnly</code>	<code>true</code>	Prevents JavaScript access via <code>document.cookie</code> ; complete XSS token theft immunity.
<code>Secure</code>	<code>true</code> (Production)	Cookies are only transmitted across TLS/HTTPS encrypted connections.
<code>SameSite</code>	<code>Lax</code>	Guards against Cross-Site Request Forgery (CSRF) on cross-origin requests.
<code>Path</code>	<code>/</code>	Accessible to all Next.js routes, server components, and API route handlers.
<code>Max-Age</code>	<code>604,800</code> / <code>2,592,000</code>	7 days default; 30 days when "Remember Me" is selected.
<code>Priority</code>	<code>High</code>	Prevents browser eviction under memory pressure during complex map rendering.

6.2 Cookie Chunking (>4096 Byte Limit)

Because large JWT payloads and metadata can exceed the 4KB browser cookie limit, `@supabase/ssr` automatically partitions tokens into sequential chunks: `sb-<project>-auth-token.0`, `sb-<project>-auth-token.1`. The server reassembles chunks seamlessly on read. When clearing sessions, all chunk indices are explicitly invalidated to prevent orphaned token leaks.

7. Silent Background Session Refresh in Middleware

Next.js 16 Edge Middleware ([src/middleware.ts](#)) silently maintains user sessions without interrupting browsing or causing map canvas re-renders.

7.1 Two-Way Cookie Mutation Pattern

When an access token's remaining TTL drops below 300 seconds (5 minutes), the middleware executes a silent refresh:

```
// Two-Way Cookie Mutation inside Middleware
export async function updateSession(request: NextRequest) {
  let supabaseResponse = NextResponse.next({ request });

  const supabase = createServerClient(
    process.env.NEXT_PUBLIC_SUPABASE_URL!,
    process.env.NEXT_PUBLIC_SUPABASE_ANON_KEY!,
    {
      cookies: {
        getAll() { return request.cookies.getAll(); },
        setAll(cookiesToSet) {
          // 1. Mutate request cookies so downstream Server Components see fresh session
          cookiesToSet.forEach(({ name, value }) => request.cookies.set(name, value));
          supabaseResponse = NextResponse.next({ request });
          // 2. Mutate response cookies so browser updates Set-Cookie header
          cookiesToSet.forEach(({ name, value, options }) =>
            supabaseResponse.cookies.set(name, value, options)
          );
        },
      },
    }
  );

  const { data: { user } } = await supabase.auth.getUser();
  return supabaseResponse;
}
```

8. Multi-Tab Session Synchronization

AbangCebu AI coordinates authentication across multiple browser tabs via the Web Platform [BroadcastChannel](#) API on channel `'supabase.auth.token'`:

Broadcast Event	Triggering Action	Behavior in Other Open Tabs
<code>SIGNED_IN</code>	Successful login in tab A	Tabs refresh server state and update auth button to profile avatar.
<code>SIGNED_OUT</code>	Explicit logout in tab A	All tabs immediately purge in-memory cache and redirect to /login .
<code>TOKEN_REFRESHED</code>	Background RTR in tab A	Tabs sync in-memory access token timer without issuing duplicate network calls.
<code>USER_UPDATED</code>	Profile update in tab A	Tabs synchronize updated name/phone in header without page reload.

9. Threat Modeling & Security Mitigations

Threat Vector	Attack Mechanism	Mitigation in AbangCebu AI
Token Replay / Theft	Exfiltrated refresh token used by attacker.	RTR Family Revocation: Presentation of used token invalidates all sessions globally.
XSS Token Harvesting	Malicious script injects into client DOM.	HTTP-Only Cookies: Tokens are completely inaccessible to client JavaScript.
Brute-Force Stuffing	Automated dictionary login attempts.	Cloudflare Turnstile CAPTCHA + IP-based rate limiting (5 attempts per 15 min).
Suspended Landlord Bypass	Banned scam landlord uses cached 1h JWT.	Middleware verifies <code>profiles.is_suspended = false</code> on every request, expelling immediately.
Open Redirect Attack	Manipulated <code>?redirect=</code> query param.	Strict destination whitelist: only relative internal paths (e.g. <code>/search</code> , <code>/dashboard</code>).

10. Error Taxonomy & Client Handling

Error Code	HTTP Status	User-Facing Message	Client Remediation
<code>AUTH_INVALID_CREDENTIALS</code>	401 Unauthorized	"Invalid email or password. Please try again."	Highlight fields; display reset password link.
<code>AUTH_EMAIL_NOT_CONFIRMED</code>	403 Forbidden	"Please confirm your email address before logging in."	Show resend confirmation email button.
<code>AUTH_RATE_LIMIT_EXCEEDED</code>	429 Too Many Req.	"Too many attempts. Please try again in 15 minutes."	Disable submit button; show cooldown countdown.
<code>AUTH_ACCOUNT_SUSPENDED</code>	403 Forbidden	"This account has been suspended for security review."	Display contact support link; clear all cookies.
<code>AUTH_SESSION_REVOKED</code>	401 Unauthorized	"Your session has expired. Please sign in again."	Clear local session state; redirect to /login.
<code>AUTH_REFRESH_TOKEN_REUSED</code>	401 Unauthorized	"Security alert: Multiple session conflicts. Signed out."	Purge all cookies; force fresh sign-in across all tabs.

Acceptance Sign-Off: Fulfills 100% of Jira SCRUM-57 acceptance criteria. Delivers full data contracts, RFC 6749 RTR rotation mechanics, Next.js 16 HTTP-Only cookie strategy, and comprehensive threat modeling without premature UI widgets.